

Pentru aceasta masina, incepem ca de obicei cu nmap.

`nmap 10.129.24.254`

```
rgmy@debian1:~/HTB_Machines/Easy/Kobold$ nmap 10.129.24.254
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-17 21:25 EEST
Nmap scan report for 10.129.24.254
Host is up (0.17s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
443/tcp   open  https
```

Vedem portul 22 pt ssh, si 80 si 443, deci probabil masina are un site https.

Sa ii dam un curl sa vedem daca mai gasim ceva pe partea http.

```
Bun, rgmy@debian1:~/HTB_Machines/Easy/Kobold$ curl 10.129.24.254
<html>
<head><title>301 Moved Permanently</title></head>
<body>
<center><h1>301 Moved Permanently</h1></center>
<hr><center>nginx/1.24.0 (Ubuntu)</center>
</body>
</html>
```

avem informatii aici, nginx/1.24.0 (Ubuntu). Este un server de ubuntu.

Adaugam in /etc/hosts urmatoarea linie pentru a ii putea da fuzz la site pe partea de https, sa putem vedea ce avem pe el. (IP-ul e in fuctie de masina generata)

`10.129.24.254 kobold.htb`

Dupa incepe fuzzingul. `ffuf -w common.txt -u https://kobold.htb/FUZZ`

```
rgmy@debian1:~/wordlist/SecLists/Discovery/Web-Content$ ffuf -w common.txt -u https://kobold.htb/FUZZ

    ____
   /'___\ /'___\ /'___\
  /\___/ /\___/  __  /\___/
 \ \ ,___/ \ \ ,___/ V \ \ ,___/
  \ \___/ \ \___/ \ \___/ \ \___/
   \ \___/ \ \___/ \ \___/ \ \___/
    V___/  V___/  V___/  V___/

v2.1.0-dev

-----

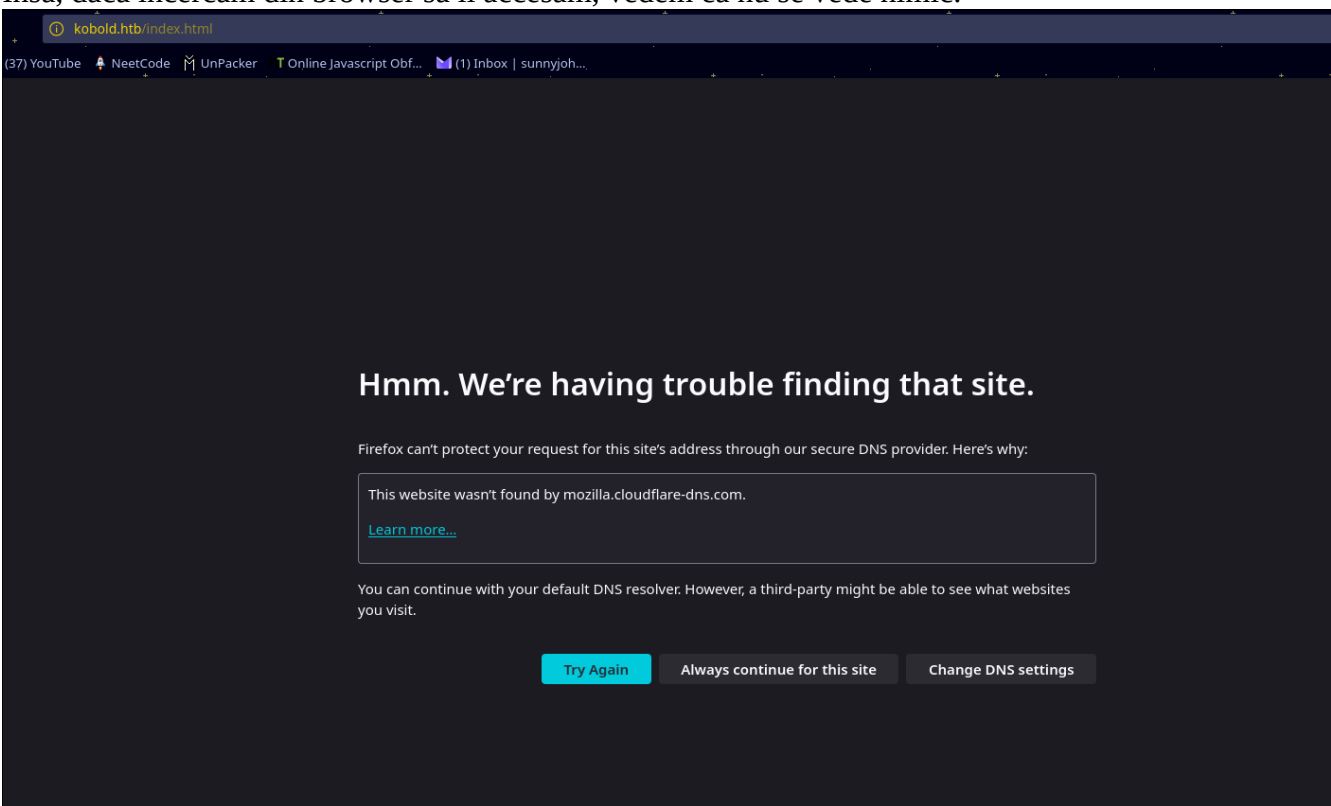
:: Method      : GET
:: URL         : https://kobold.htb/FUZZ
:: Wordlist    : FUZZ: /home/rgmy/wordlist/SecLists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

-----

index.html      [Status: 200, Size: 3812, Words: 992, Lines: 187, Duration: 57ms]
```

Am gasit index.html.

Insa, daca incercam din browser sa il accesam, vedem ca nu se vede nimic.



Deci, o sa facem o analiza local. Pentru a lua codul html, o sa ii dam wget si il luam la noi pe masina.

```
wget --no-check-certificate https://kobold.htb/index.html
```

Am pus --no-check-certificate pentru ca se plangea wget-ul ca "NOT SAFE CERTIFICATE".

Acum, sa analizam codul. Din toate lucrurile care ar putea fi interesanta, este partea de la final

2026 Kobold Systems · Contact: admin@kobold.htb

Stim ca exista deci un user admin. Daca incercam sa dam ssh direct la el (am pus kobold.htb in hosts), deci putem da direct `ssh admin@kobold.htb`, vedem ca suntem pusi sa punem parola:

```
rgmy@debian1:~/wordlist/SecLists/Discovery/Web-Content$ ssh admin@kobold.htb
admin@kobold.htb's password:
```

Deci, aici urmeaza sa intram eventual, mult mai incolo.

Înapoi la cautat. Acum ca știm că există contul de admin, putem să vedem dacă există ceva subdomenii disponibile.

```
ffuf -w subdomains-top1million-20000.txt -u https://kobold.htb -H "Host: FUZZ.kobold.htb" -k -fs 154
```

```
rgmy@debian1:~/wordlist/SecLists/Discovery/DNS$ ffuf -w subdomains-top1million-20000.txt -u https://kobold.htb -H "Host: FUZZ.kobold.htb" -k -fs 154
```

```

      /\_/\  /\_/\  /\_/\
     /\_/\  /\_/\  --  /\_/\
    /\_/\  /\_/\  /\_/\  /\_/\  /\_/\
   /\_/\  /\_/\  /\_/\  /\_/\  /\_/\
  /\_/\  /\_/\  /\_/\  /\_/\  /\_/\
 /\_/\  /\_/\  /\_/\  /\_/\  /\_/\
/_/\  _/\_/\  /\_/\  /\_/\  /\_/\

v2.1.0-dev
-----

:: Method          : GET
:: URL             : https://kobold.htb
:: Wordlist        : FUZZ: /home/rgmy/wordlist/SecLists/Discovery/DNS/subdomains-top1million-20000.txt
:: Header         : Host: FUZZ.kobold.htb
:: Follow redirects : false
:: Calibration     : false
:: Timeout        : 10
:: Threads        : 40
:: Matcher        : Response status: 200-299,301,302,307,401,403,405,500
:: Filter         : Response size: 154
-----

bin                [Status: 200, Size: 24402, Words: 1218, Lines: 386, Duration: 216ms]
mcp                [Status: 200, Size: 466, Words: 57, Lines: 15, Duration: 262ms]
:: Progress: [20000/20000] :: Job [1/1] :: 568 req/sec :: Duration: [0:00:30] :: Errors: 0 ::
```

Am gasit 2 subdomenii, hai sa le vedem. (trebuie adaugate si ele in hosts ca sa mearga ffuf!!).

```
ffuf -w common.txt -u https://mcp.kobold.htb/FUZZ -k -fs 466 (466 pt ca la baza da return la raspunsul 200 la orice cerere)
```

Am gasit astfel health.

```
rgmy@debian1:~/wordList/SecLists/Discovery/Web-Content$ ffuf -w common.txt -u https://mcp.kobold.htb/FUZZ -k -fs 466
```



```
v2.1.0-dev
```

```
:: Method      : GET
:: URL         : https://mcp.kobold.htb/FUZZ
:: Wordlist     : FUZZ: /home/rgmy/wordList/SecLists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 466
```

```
health [Status: 200, Size: 54, Words: 1, Lines: 1, Duration: 63ms]
```

Hai sa dam un curl peste el.

`curl -k -s https://mcp.kobold.htb/health/`

```
rgmy@debian1:~/wordList/SecLists/Discovery/Web-Content$ curl -k -s https://mcp.kobold.htb/health/
<!doctype html>
<html lang="en">
  <head>
    <meta charset="UTF-8" />
    <link rel="icon" type="image/svg+xml" href="/mcp_jam.svg" />
    <meta name="viewport" content="width=device-width, initial-scale=1.0" />
    <title>MCPJam Inspector</title>
    <script type="module" crossorigin src="/assets/index-DRYhT9Xb.js"></script>
    <link rel="stylesheet" crossorigin href="/assets/index-XvFRNbCs.css">
  </head>
  <body>
    <div id="root"></div>
  </body>
</html>
```

Vedem trei pathuri interesante: /mcp_jam.svg, /assets/index-DRYhT9Xb.js, /assets/index-XvFRNbCs.css.

Hai sa vedem ce avem acolo:

Dam wget la toate pathurile pentru fisiere, si la final de /assets/index-DRYhT9Xb.js, vedem urmatorul rand comentat:

`//# sourceMappingURL=index-DRYhT9Xb.js.map`

Hai sa il vedem si pe acesta. E tot pe o singura linie, si e posibil sa ia mult timp sa gasesc ceva, avand si foarte multe comentarii. Sa merg sa ma uit intai si la celalt domain gasit.

`ffuf -w common.txt -u https://bin.kobold.htb/FUZZ -k -fw 1218`

```
rgmy@debian1:~/wordlist/SecLists/Discovery/Web-Content$ ffuf -w common.txt -u https://bin.kobold.htb/FUZZ -k -fw 1218
```

```
/'---\ /'---\ /'---\
/\ \_/\ /\ \_/\  _ _  /\ \_/\
\ \ ,--\ \ \ ,--\ \ \ \ \ \ \ ,--\
\ \ \_/\ \ \ \_/\ \ \ \_/\ \ \ \_/\
\ \ \_/\ \ \ \_/\ \ \ \_/\ \ \ \_/\
\ \ \_/\ \ \ \_/\ \ \ \_/\ \ \ \_/\
```

v2.1.0-dev

```
-----
:: Method      : GET
:: URL         : https://bin.kobold.htb/FUZZ
:: Wordlist     : FUZZ: /home/rgmy/wordlist/SecLists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout      : 10
:: Threads     : 40
:: Matcher      : Response status: 200-299,301,302,307,401,403,405,500
:: Filter       : Response words: 1218
-----
```

```
css      [Status: 301, Size: 162, Words: 5, Lines: 8, Duration: 278ms]
img      [Status: 301, Size: 162, Words: 5, Lines: 8, Duration: 131ms]
js       [Status: 301, Size: 162, Words: 5, Lines: 8, Duration: 125ms]
robots.txt [Status: 200, Size: 376, Words: 49, Lines: 13, Duration: 124ms]
:: Progress: [4751/4751] :: Job [1/1] :: 266 req/sec :: Duration: [0:00:18] :: Errors: 0 ::
```

Am gasit niste fisiere noi. Sa incep cu cel mai usor, robots.txt, poate are ceva (nu are de obicei nimic)

```
rgmy@debian1:~/wordlist/SecLists/Discovery/Web-Content$ curl -k -s https://bin.kobold.htb/robots.txt
```

```
# "A robots.txt a day keeps the robots away."
# (for performance and privacy reasons)
#
# Note: To be effective this robots.txt must be put into the root of your server
# directory.

User-agent: *
Disallow: /

# If you don't want this instance to be listed on https://privatebin.info/directory/
# uncomment the following lines:
#User-agent: PrivateBinDirectoryBot
#Disallow: /rgmy@debian1:~/wordlist/SecLists/Discovery/Web-Content$ |
```

Acum, hai sa dam fuzz pentru js, css si img.

```
ffuf -w common.txt -u https://bin.kobold.htb/js/FUZZ -k -fw 1218
```

```
rgmy@debian1:~/wordlist/SecLists/Discovery/Web-Content$ ffuf -w common.txt -u https://bin.kobold.htb/js/FUZZ -k -fw 1218

  /'---\ /'---\ /'---\
 \___/ \___/ \___/
  /'---\ /'---\ /'---\
 \___/ \___/ \___/
  /'---\ /'---\ /'---\
 \___/ \___/ \___/
  /'---\ /'---\ /'---\
 \___/ \___/ \___/

v2.1.0-dev

-----

:: Method      : GET
:: URL         : https://bin.kobold.htb/js/FUZZ
:: Wordlist     : FUZZ: /home/rgmy/wordlist/SecLists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout      : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response words: 1218

-----

package.json      [Status: 200, Size: 1105, Words: 186, Lines: 44, Duration: 141ms]
package-lock.json [Status: 200, Size: 122801, Words: 22622, Lines: 3280, Duration: 232ms]
:: Progress: [4751/4751] :: Job [1/1] :: 218 req/sec :: Duration: [0:00:15] :: Errors: 0 ::
```

Am gasit doua fisiere.

Am dat wget la package.json. Si am analizat continutul.

```
rgmy@debian1:~/HTB_Machines/Easy/Kobold$ cat package.json
{
  "name": "privatebin",
  "version": "2.0.2",
  "description": "PrivateBin is a minimalist, open source online pastebin where the server has zero knowledge of stored data. Data is encrypted/decrypted in the browser using 256 bit AES in Galois Counter mode (GCM).",
  "main": "privatebin.js",
  "directories": {
    "test": "test"
  },
}
```

Folosim privatebin 2.0.2.

Inapoi la acel index-DRYhT9Xb.js.map (: () . Ma pot uita cu grep prin el sa vad daca am ceva rute acolo.

Pentru api calluri:

```
grep -oE '/api/[a-zA-Z0-9_-]+' index-DRYhT9Xb.js.map | sort -u
```



```
rgmy@debian1:~/HTB_Machines/Easy/Kobold$ grep -oE '/api/[a-zA-Z0-9_-]+/' index-DRYhT9Xb.js.map | sort -u
/api/apps/chatgpt/sandbox-proxy
/api/apps/chatgpt/widget-content/
/api/apps/chatgpt/widget-html/
/api/apps/chatgpt/widget/store
/api/chat
/api/classes/browser
/api/coding/paas/v4
/api/completion
/api/debug_event
/api/early_access_features/
/api/mcp/adapter-http/
/api/mcp/apps/widget-content/
/api/mcp/apps/widget/store
/api/mcp/chat
/api/mcp/chat-v2
/api/mcp/cli-config
/api/mcp/connect
/api/mcp/elicitation/respond
/api/mcp/elicitation/stream
/api/mcp/evals/generate-negative-tests
/api/mcp/evals/generate-tests
/api/mcp/evals/run
/api/mcp/evals/run-test-case
/api/mcp/export/server
/api/mcp/list-tools
/api/mcp/log-level
/api/mcp/oauth/debug/proxy
/api/mcp/oauth/metadata
/api/mcp/oauth/proxy
/api/mcp/prompts/get
/api/mcp/prompts/list
/api/mcp/prompts/list-multi
/api/mcp/resources/list
/api/mcp/resources/read
/api/mcp/resource-templates/list
/api/mcp/sandbox-proxy
/api/mcp/servers
/api/mcp/servers/
/api/mcp/servers/init-info/
/api/mcp/servers/reconnect
/api/mcp/servers/rpc/stream
/api/mcp/tasks/cancel
/api/mcp/tasks/capabilities
/api/mcp/tasks/get
/api/mcp/tasks/list
/api/mcp/tasks/progress
/api/mcp/tasks/progress/all
/api/mcp/tasks/result
/api/mcp/tokenizer/count-text
/api/mcp/tokenizer/count-tools
/api/mcp/tools/execute
/api/mcp/tools/list
/api/mcp/tools/respond
/api/mcp/tunnels
/api/mcp/tunnels/cleanup-orphaned
/api/mcp/tunnels/create
/api/mcp/tunnels/server/
/api/paas/v4
/api/product_tours/
/api/surveys/
/api/users
/api/util
```

Pentru orice altceva:

```
grep -oE ""[a-zA-Z0-9_-]+:[a-zA-Z0-9_-]+"" index-DRYhT9Xb.js.map | sort -u
```

```
rgmy@debian1:~/HTB_Machines/Easy/Kobold$ grep -oE "[a-zA-Z0-9_-]+:[a-zA-Z0-9_-]+" index-DRYhT9Xb.js.map | sort -u
"\\\\:\""
"about:blank\""
"blob:\""
"color:\""
"contentEncoding:base64\""
"data:\""
"file:\""
"format:binary\""
"format:date\""
"format:date-time\""
"format:email\""
"format:ids-email\""
"hover:scale-105\""
"hover:shadow-sm\""
"http:\""
"https:\""
"irc:\""
"ircs:\""
"javascript:\""
"mailto:\""
"margin-right:\""
"mcp-apps:csp-violation\""
"\\nData:\""
"\\nError:\""
"openai:\""
"openai:callTool\""
"openai:csp-violation\""
"openai:load-widget\""
"openai:navigate\""
"openai:navigationStateChanged\""
"openai:openExternal\""
"openai:pushWidgetState\""
"openai:requestCheckout\""
"openai:requestClose\""
"openai:requestDisplayMode\""
"openai:requestModel\""
"openai:requestResize\""
"openai:resize\""
"openai:sandbox-ready\""
"openai:sendFollowup\""
"openai:set_globals\""
"openai:setWidgetState\""
"pattern:zod\""
"RADIX:SYNC_STATE\""
"rv:\""
"safari-extension:\""
"safari-web-extension:\""
"sm:justify-between\""
"sm:max-w-md\""
"streamdown:incomplete-link\""
"testSuites:cancelTestSuiteRun\""
"testSuites:createTestCase\""
"testSuites:createTestSuite\""
"testSuites:deleteTestCase\""
"testSuites:deleteTestSuite\""
"testSuites:deleteTestSuiteRun\""
"testSuites:duplicateTestCase\""
"testSuites:duplicateTestSuite\""
"testSuites:getAllTestCasesAndIterationsBySuite\""
"testSuites:getTestIteration\""
"testSuites:getTestIterationBlob\""

```

Am incercat mai multe curluri pentru acele api-uri, dar fara succes. Inapoi cu mine la nmap, poate am sarit ceva.

nmap -p- --min-rate 5000 10.129.24.254

```
rgmy@debian1:~/HTB_Machines/Easy/Kobold$ nmap -p- --min-rate 5000 10.129.24.254
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-17 22:50 EEST
Nmap scan report for kobold.htb (10.129.24.254)
Host is up (0.063s latency).
Not shown: 65528 closed tcp ports (conn-refused)
PORT      STATE      SERVICE
22/tcp    open      ssh
80/tcp    open      http
443/tcp   open      https
3552/tcp   open      taserver
3882/tcp   filtered  msdts1
33960/tcp  filtered  unknown
60283/tcp  filtered  unknown

```

Evident, am ratat portul 3552 ultima oara, dar 3552 nu e un port obisnuit, hai sa vad ce ruleaza pe el.

nmap -p 3552 -sV -sC 10.129.24.254


```

PORT      STATE SERVICE VERSION
3552/tcp  open  http      GoLang net/http server
|_http-title: Site doesn't have a title (text/html; charset=utf-8).
|_fingerprint-strings:
|_GenericLines:
|_   HTTP/1.1 400 Bad Request
|_   Content-Type: text/plain; charset=utf-8
|_   Connection: close
|_   Request
|_GetRequest:
|_   HTTP/1.0 200 OK
|_   Accept-Ranges: bytes
|_   Cache-Control: no-cache, no-store, must-revalidate
|_   Content-Length: 2081
|_   Content-Type: text/html; charset=utf-8
|_   Expires: 0
|_   Pragma: no-cache
|_   Date: Wed, 17 Jun 2026 19:55:03 GMT
|_   <!doctype html>
|_   <html lang="%Lang%">
|_   <head>
|_   <meta charset="utf-8" />
|_   <meta http-equiv="Cache-Control" content="no-cache, no-store, must-revalidate" />
|_   <meta http-equiv="Pragma" content="no-cache" />
|_   <meta http-equiv="Expires" content="0" />
|_   <link rel="icon" href="/api/app-images/favicon" />
|_   <meta name="viewport" content="width=device-width, initial-scale=1, maximum-scale=1, viewport-fit=cover" />
|_   <link rel="manifest" href="/app.webmanifest" />
|_   <meta name="theme-color" content="oklch(1 0 0)" media="(prefers-color-scheme: light)" />
|_   <meta name="theme-color" content="oklch(0.141 0.085 285.823)" media="(prefers-color-scheme: dark)" />
|_   <link rel="modu
|_HTTPOptions:
|_   HTTP/1.0 200 OK
|_   Accept-Ranges: bytes
|_   Cache-Control: no-cache, no-store, must-revalidate
|_   Content-Length: 2081
|_   Content-Type: text/html; charset=utf-8
|_   Expires: 0
|_   Pragma: no-cache
|_   Date: Wed, 17 Jun 2026 19:55:04 GMT
|_   <!doctype html>
|_   <html lang="%Lang%">

```

Un server golang...

Fuzz si pe el...

```
rgmy@debian1:~/wordlist/SecLists/Discovery/Web-Content$ ffuf -w common.txt -u http://10.129.24.254:3552/FUZZ -fs 2081
```

v2.1.0-dev

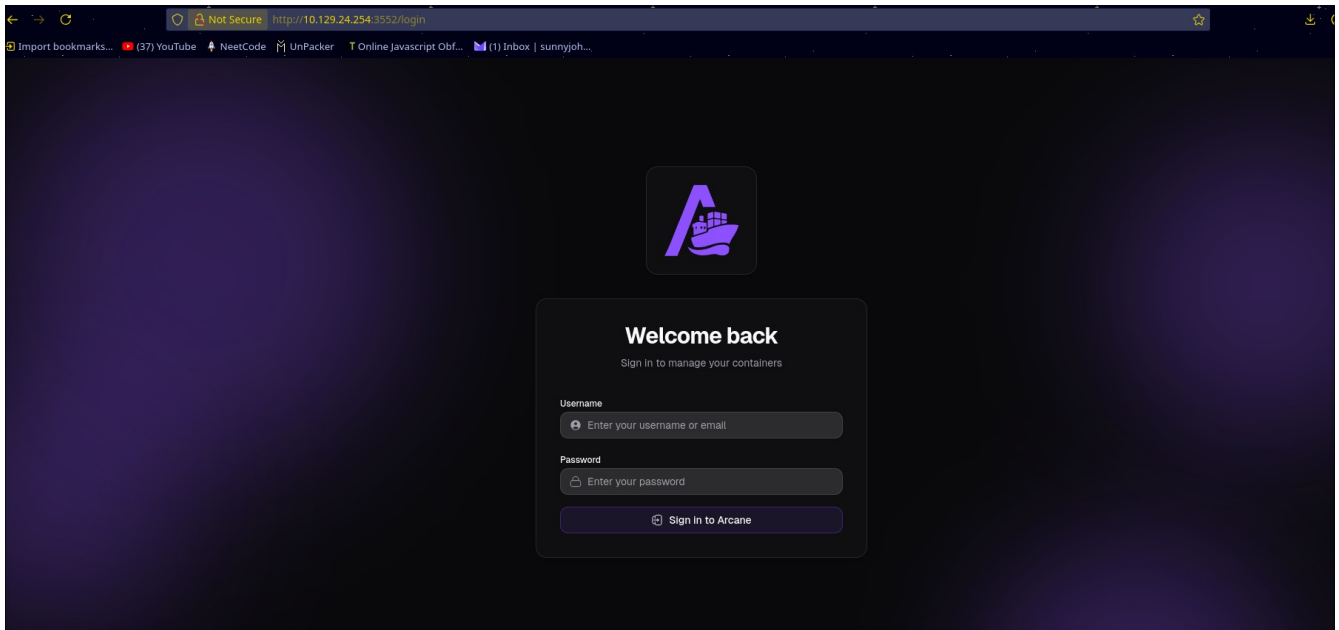
```

:: Method      : GET
:: URL         : http://10.129.24.254:3552/FUZZ
:: Wordlist    : FUZZ: /home/rgmy/wordlist/SecLists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 2081

```

```
img [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 83ms]
index.html [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 75ms]
:: Progress: [4751/4751] :: Job [1/1] :: 573 req/sec :: Duration: [0:00:07] :: Errors: 0 ::
```

Primul index.html care chiar se vede in browser.



Sa ii dau curl la cod si gasim mai multe pathuri.

```

rgmy@debian1:~/wordlist/SecLists/Discovery/Web-Content$ curl -i http://10.129.24.254:3552/login
HTTP/1.1 200 OK
Accept-Ranges: bytes
Cache-Control: no-cache, no-store, must-revalidate
Content-Length: 2081
Content-Type: text/html; charset=utf-8
Expires: 0
Pragma: no-cache
Date: Wed, 17 Jun 2026 20:00:35 GMT

<!doctype html>
<html lang="%Lang%">
  <head>
    <meta charset="utf-8" />
    <meta http-equiv="Cache-Control" content="no-cache, no-store, must-revalidate" />
    <meta http-equiv="Pragma" content="no-cache" />
    <meta http-equiv="Expires" content="0" />
    <link rel="icon" href="/api/app-images/favicon" />
    <meta name="viewport" content="width=device-width, initial-scale=1, maximum-scale=1, viewport-fit=cover" />
    <link rel="manifest" href="/app.webmanifest" />
    <meta name="theme-color" content="oklch(1 0 0)" media="(prefers-color-scheme: light)" />
    <meta name="theme-color" content="oklch(0.141 0.005 285.823)" media="(prefers-color-scheme: dark)" />

    <link rel="modulepreload" href="/_app/immutable/entry/start.B8B5EbJt.js">
    <link rel="modulepreload" href="/_app/immutable/chunks/DwHmfVrp.js">
    <link rel="modulepreload" href="/_app/immutable/chunks/Dvtn3SXU.js">
    <link rel="modulepreload" href="/_app/immutable/chunks/0hPeTpoK.js">
    <link rel="modulepreload" href="/_app/immutable/chunks/BUApaBEI.js">
    <link rel="modulepreload" href="/_app/immutable/entry/app.DjeIUeIu.js">
    <link rel="modulepreload" href="/_app/immutable/chunks/PPVm8Dsz.js">
    <link rel="modulepreload" href="/_app/immutable/chunks/CG2WSiiR.js">
    <link rel="modulepreload" href="/_app/immutable/chunks/DsnmJJEf.js">
    <link rel="modulepreload" href="/_app/immutable/chunks/6YvvyG1B.js">
    <link rel="modulepreload" href="/_app/immutable/chunks/CZ6RKXrE.js">
  </head>
  <body data-sveltekit-preload-data="hover">
    <div style="display: contents">
      <script>
        {
          __sveltekit_1qbikdi = {
            base: ""
          };

          const element = document.currentScript.parentElement;

          Promise.all([
            import("/_app/immutable/entry/start.B8B5EbJt.js"),
            import("/_app/immutable/entry/app.DjeIUeIu.js")
          ]).then(([kit, app]) => {
            kit.start(app, element);
          });

          if ('serviceWorker' in navigator) {
            addEventListener('load', function () {
              navigator.serviceWorker.register('/service-worker.js');
            });
          }
        }
      </script>
    </div>
  </body>
</html>

```

Am dat wget la acele hrefuri pentru analiza.
 Intre timp am dat fuzz si pentru pathul de /api.

